

6.3.4 Risk Management Process

6.3.4.1 Purpose

The purpose of the Risk Management Process is to systematically address risks throughout the life cycle of a system, software product, or service. It applies to risks related to acquisition, development, maintenance, and operation.

6.3.4.2 Outcomes

As a result of successful implementation of the Risk Management Process:

- a) The scope of risk management to be performed is determined.
- b) Appropriate risk management strategies are defined and implemented.
- c) Risks are identified as they develop and during project conduct.
- d) Risks are analyzed, prioritized, and resources allocated accordingly.
- e) Risk measures are defined, applied, and assessed to determine changes in risk status and treatment progress.
- f) Risk treatments are applied based on priority, probability, consequence, or other defined risk thresholds, to correct or avoid impacts.
- g) The effectiveness and efficiency of the Risk Management Process are periodically evaluated and improved.

Reference: ISO/IEC 16085 provides a more detailed set of activities and tasks aligned with those described below.

6.3.4.3 Activities and Tasks

The project shall implement the following activities and tasks in accordance with applicable organizational policies and procedures.

6.3.4.3.1 Risk Management Planning

This activity establishes the framework for conducting risk management throughout the project life cycle.

- 6.3.4.3.1.1 Define organizational risk management policies and

strategies.

- 6.3.4.3.1.2 Document the Risk Management Process, including its scope and applicability.
 - 6.3.4.3.1.3 Identify responsible parties and define their roles, authorities, and responsibilities for risk management.
 - 6.3.4.3.1.4 Provide adequate resources to responsible parties to execute the process effectively.
 - 6.3.4.3.1.5 Define procedures for evaluating and improving the Risk Management Process, including capturing lessons learned for continuous improvement.
-

6.3.4.3.2 Risk Profile Management

This activity defines the context and maintains a structured representation of risks and their status.

- 6.3.4.3.2.1 Define and document the risk management context, including:
 - Stakeholder perspectives
 - Risk categories (technical, managerial, operational, contractual, etc.)
 - Objectives, assumptions, and constraints.
 - 6.3.4.3.2.2 Define risk thresholds to determine acceptable levels of risk.
 - 6.3.4.3.2.3 Establish and maintain a **risk profile**, which includes:
 - Context information
 - Identified risks with probability and consequence estimates
 - Thresholds and priorities based on stakeholder criteria
 - Treatment requests and status.
 - 6.3.4.3.2.4 Update the risk profile when the state of any risk changes.
 - 6.3.4.3.2.5 Communicate relevant parts of the risk profile to stakeholders periodically, based on their needs and roles.
-

6.3.4.3.3 Risk Analysis

This activity identifies, estimates, and evaluates risks to support prioritization and treatment planning.

- 6.3.4.3.3.1 Identify risks within the defined context, including internal and external sources, during all phases of the life cycle.
- 6.3.4.3.3.2 Estimate each risk's probability of occurrence and consequence of impact using defined methods and criteria.
- 6.3.4.3.3.3 Evaluate each risk against defined thresholds to determine whether treatment is required.

- 6.3.4.3.3.4 Define and document recommended treatment strategies for risks that exceed thresholds, along with indicators to measure their effectiveness.
 - 6.3.4.3.3.5 Categorize and prioritize risks for resource allocation based on probability, consequence, and stakeholder-defined criteria.
-

6.3.4.3.4 Risk Treatment

This activity defines and implements strategies for addressing identified risks.

- 6.3.4.3.4.1 Provide stakeholders with recommended alternative treatments through risk action requests.
 - 6.3.4.3.4.2 Implement selected risk treatment alternatives.
 - 6.3.4.3.4.3 Typical treatment strategies include:
 - Eliminating the risk
 - Reducing its probability of occurrence
 - Mitigating its consequences
 - Accepting the risk under defined conditions.
 - 6.3.4.3.4.4 High-priority risks shall be monitored continuously to determine if further treatment is required.
 - 6.3.4.3.4.5 Once a treatment is selected, manage it as a problem in accordance with the assessment and control activities in 6.3.2 Measurement Process, and track through Configuration Management (6.3.5, if present).
-

6.3.4.3.5 Risk Monitoring

This activity ensures that risk states and the risk context are continuously observed and evaluated.

- 6.3.4.3.5.1 Continuously monitor all identified risks and the risk context for changes.
 - 6.3.4.3.5.2 Re-evaluate risks whose states have changed to determine if further analysis or treatment is required.
 - 6.3.4.3.5.3 Implement and monitor measures to evaluate the effectiveness of risk treatments.
 - 6.3.4.3.5.4 Continuously monitor for new risks and emerging sources throughout the life cycle.
 - 6.3.4.3.5.5 Report risk status and trends to stakeholders and decision-makers (see 6.3.3 Decision Management).
-

6.3.4.3.6 Risk Management Process Evaluation

This activity evaluates the effectiveness and efficiency of the Risk Management Process.

- 6.3.4.3.6.1 Collect risk management data throughout the project for evaluation and lessons learned.
 - 6.3.4.3.6.2 Periodically review the process for effectiveness and efficiency, identifying areas for improvement.
 - 6.3.4.3.6.3 Update risk management procedures and policies based on lessons learned and evaluation results.
-

Cross-References

This process interacts with and supports:

- **Measurement Process (6.3.2)** — for monitoring risk measures and treatment effectiveness.
- **Decision Management Process (6.3.3)** — for selecting among risk treatment alternatives.
- **Configuration Management Process (6.3.5)** — for controlling risk-related changes to baselined items.
- **Review (7.2.6)** and **Audit (7.2.7)** — for assessing risk management practices and outcomes.